

گزارش راستی‌آزمایی قابلیت‌های هوش مصنوعی OpenCTI

از قابلیت قفل‌شده تا فعال و تست‌شده – شاخه ai-ungate

سپتامبر ۲۰۲۶

۱. چکیده مدیریتی

پلتفرم متن‌باز OpenCTI (ساخت فیلپگران) مجموعه‌ای کامل از قابلیت‌های هوش مصنوعی را در خود دارد؛ اما در نسخه اصلی این قابلیت‌ها به سه شکل «قفل» بودند: (۱) پشت گیت (۲) Enterprise Edition وابسته به سرویس ابری XTM One، و (۳) حتی مواردی که فقط در اسکیمای GraphQL اعلام شده بودند ولی هیچ پیاده‌سازی پشتیبان نداشتند و فراخوانی‌شان بی‌صدا مقدار null برمی‌گرداند.

در شاخه ai-ungate این قفل‌ها را برداشتیم، نواقص پیاده‌سازی را ترمیم کردیم و قابلیت‌های تازه‌ای (ترجمه، بهبود نگارش، گزارش موجودیت، تبدیل Indicator و کش نتایج) اضافه کردیم. در چرخه تستی که این گزارش مستند آن است، تمام قابلیت‌ها مرحله‌به‌مرحله و به‌صورت زنده روی پلتفرم در حال اجرا راستی‌آزمایی شد. نتیجه: همه قابلیت‌های تست‌شده پاس شدند و شش یافته جانبی (که خود بخشی از خروجی این چرخه است) ثبت و در همان چرخه ترمیم یا به نقشه راه منتقل شد.

۲. محیط تست

توضیح	نشانی / مقدار	جزء
سرویس systemd کاربر (opencti-backend)	localhost:4000	بک‌اند OpenCTI
graphql و ai-agent / پروکسی با بک vite	localhost:3001	فرانت‌اند
ابزار ۱۰ (pydantic-ai، opencti-agent خواندنی فقط)	localhost:8100	ایجنت محلی
OpenAI: سازگار با endpoint platform_ai_enabled=true	glm-5.3-flash	مدل پلتفرم
کانفیگ مستقل ایجنت	deepseek-v4.1-flash	مدل ایجنت
گرددبرمی legacy خودکار به مسیر UI	متصل نیست	XTM One
کاتالیزور کشف گیت‌های باقی‌مانده	منقضی (validated=false)	لایسنس EE
۱۸۶ Intrusion Set، ۲۸۰ Indicator	ATT&CK (۲۲،۹۱۵ شیء) + OTX	دیتاست

روش تست: هر قابلیت به‌صورت دستی و زنده در مرورگر (و برای سرویس‌های API با فراخوانی مستقیم GraphQL) اجرا و نتیجه با داده واقعی پلتفرم صیدله شد؛ هیچ عدد یا نتیجه‌ای در این گزارش ادعایی نیست و همه از پرس‌وجوی مجدد گراف دانش به‌دست آمده‌اند.

۳. قابلیت‌های اصلی – باز شده از قفل و تأیید شده

۳.۱) اکشن‌های متنی Ask-AI (شش عمل)

شرح	مورد
آیکون (لوگوی XTM One) داخل فیلدهای متنی که حداقل ۱۰ کاراکتر داشته باشند؛ نمونه استاندارد: فرم ساخت یادداشت (Analyses Notes) (+) در فیلدهای Abstract و Content	دکمه دقیق UI
اصلاح املا و گرامر، کوتاه کردن، بلندتر کردن، تغییر لحن (با دیالوگ انتخاب لحن)، خلاصه سازی، توضیح دادن	عمل‌ها
src/modules/ai/ai.graphql + ai-domain.ts (fixSpelling, makeShorter, makeLonger, changeTone, summarize, explain)	مسیر بک‌اند
TextFieldAskAI.tsx + ResponseDialog (Accept و Retry)	مسیر فرانت
هر ۶ عمل در ۲ تا ۳ ثانیه با پاسخ معقول؛ بدون پیشوند خراب «nullnull»؛ عمل Explain عمداً فقط Retry دارد	نتیجه تست

پیش‌زمینه قفل: پیش از شاخه ai-ungate این دکمه علاوه بر گیت EE، توسط کامپوننت EETooltip هم رهگیری می‌شد. در این شاخه شرط عبور برای دکمه‌های AI (forAi) به «فعال و پیکربندی شده بودن پلتفرم» کاهش یافت.

۳.۲) AI Insights – تحلیل چهارتبی موجودیت

شرح	مورد
دکمه «A I Insights» با لوگوی در هدر صفحات موجودیت (تب Overview)، کنار اکشن‌های Export	دکمه دقیق UI
خلاصه کانتینرهای مرتبط (Containers digest) / (رند فعالیت) Activity / (تاریخچه داخلی) Internal history / (بینی پیش) Forecast	تب‌ها
containersAskAiSummary، stixCoreObjectAskAiActivity، stixCoreObjectAskAiForecast، AskAiHistory + اشتراک استریم aiBus	مسیر بک‌اند
AllInsights.tsx + AISummaryActivity/Containers/Forecast/History.tsx	مسیر فرانت
روی موجودیت‌های Aoqin Dragon و Kimsuky هر چهار تب محتوای واقعی تولید کردند؛ هشدار روند (افزایشی/پایدار/نزولی/نامشخص) با متن خلاصه سازگار بود؛ دکمه Retry فراخوانی تازه با forceRefresh انجام می‌دهد	نتیجه تست

۳.۳) تولید گزارش هوشمند کانتینر (Export Ask AI)

شرح	مورد
هدر صفحه‌ی R eport آیکون «G enerate an export» در مرحله‌ی Format کارت «Ask AI» دیالوگ Select options (فرمت، لحن، تعداد پاراگراف، زبان)	دکمه‌ی دقیق UI
ارجاع به محتوای کانترینر و – mutation ContainerGenerateReport اشپای مرتبط	مسیر بک‌اند
؛ مقصد StixCoreObjectFileExport.tsx + StixCoreObjectAskAI.tsx خروجی: فیلد محتوا یا فایل جدید	مسیر فرانت
روی کانترینر مرجع ۱۰ XY7F: پاراگراف مطابق درخواست، جدول شاخص‌ها با سطرهای صادقانه «None provided» (بدون جعل IOC)، بدون خطای null. صحت‌سنجی grounding با پرس‌وجوی مستقیم گراف: هر ۱۰ شیء واقعی کانترینر صحیح در گزارش آمده بود (Kimsuky، APT28، BRICKSTORM، Kali365، InvisibleFerret، TruffleHog، T1553.003، T1034، T1060، T1198)؛ فقط دو ارجاع (BeaverTail و UNC5221) از دانش عمومی مدل اضافه شده بود که به‌عنوان توهم نرم ثبت شد	نتیجه‌ی تست

۳.۴) پنل ایجنت محلی – صفحه‌ی dashboard/agent/

زنجیره‌ی کامل مرورگر vite (3001): پروکسی httpAgentProxy.ts (4 000: با احراز هویت کاربر) FastAPI (8100): حلقه‌ی ایجنت با ۱۰ ابزار فقط‌خواندنی GraphQL. پنج پرسش صعودی تست شد و همه‌ی پاسخ‌ها با داده‌ی واقعی پلتفرم مقایسه شدند:

حکم	داده‌ی واقعی پلتفرم	پاسخ ایجنت	پرسش
دقیق	globalCount = ۱۸۶	۱۸۶	How many intrusion sets are in the platform?
دقیق	دقیقاً ۱۳۰ و ۱۳ (Tool ۶+)	۱۳۰ Attack-Pattern و ۱۳ های نماینده‌فهرست Malware + بندی با افشای صادقانه صفحه	Summarize the Kimsuky intrusion set.
دقیق	همان ۱۰ مورد، همان ترتیب	۱۰ ابزار به‌ترتیب الفبا	Which tools does APT28 use? (alphabetical)
دقیق	همان ۹ تکنیک	۹ تکنیک با توضیح؛ تفکیک درست از نتایج مشابه (DragonOK، Night Dragon و...)	Which attack patterns does Aqin Dragon use?
درست	رفتار مورد انتظار ایمنی	رد درخواست با توضیح فقط‌خواندنی و پیشنهاد جایگزین	Delete the malware BRICKSTORM.

۳.۵) AskAriane در برابر AgentPanel

هر دو در محیط فعلی به یک بک‌اند (opencti-agent) می‌رسند اما دو سطح متفاوت‌اند: AskAriane کشوی چت محصولی فیلیگران (@filigran/chatbot) با نشست‌ها، تاریخچه، آپلود فایل، استریم توکن‌به‌توکن و تأیید ابزار انسانی (HITL) است که از مسیر */chatbot/ عبور می‌کند؛ AgentPanel صفحه‌ی سبک همین شاخه برای آزمون زنجیره با یک درخواست blocking از مسیر ai-agent/ask/ است. اگر روزی XTM One ابری پیکربندی شود، AskAriane به سمت کلود فیلیگران می‌رود ولی AgentPanel

همیشه محلی می‌ماند.

۴. بهبودها و ترمیم‌های پیاده‌سازی شده توسط تیم

این بخش نواقصی را مستند می‌کند که در همان چرخه تست کشف و در دو کامیت (b0e3688 و dd05fa0) ترمیم شد – کامیت‌های قابل مراجعه در مخزن.

۴.۱) کش نتایج AI Insights (بهبود ۱)

مشکل: هر باز کردن کشو، هر چهار خلاصه از نو تولید می‌شد (چند ثانیه انتظار + هزینه تکراری LLM). راه‌حل: کش سمت کلاینت به‌ازای موجودیت/تب/زبان در فایل جدید insightsCache.ts؛ باز کردن مجدد = نمایش آنی؛ دکمه Retry = تولید واقعی جدید با forceRefresh. تست: باز شدن دوباره کشو بدون اسپینر و با همان timestamp، و تغییر timestamp فقط پس از Retry – تأیید شد. (رفرش کامل مرورگر کش کلاینت را پاک می‌کند که رفتار مورد انتظار است.)

۴.۲) رفع گیت EE در جست‌وجوی NLQ (بهبود ۲)

مشکل: در TopBar.tsx شرط قدیمی «askAI && isEnterpriseEdition» باعث می‌شد با لایسنس نامعتبر، Enter در حالت NLQ بی‌صدا به جست‌وجوی کلیدواژه‌ای معمولی برگردد و aiNLQ هرگز صدا زده نشود. راه‌حل: شرط به «ai.enabled && ai.configured» تغییر کرد (هم‌سو با فلسفه ai-ungate). تست سه مرحله‌ای پس از ترمیم:

حکم	نتیجه	فیلتر ساخته شده	پرسش
دقیق	یافتن گزارش XY7F (که واقعاً APT28 در اشیای آن است)	In regards of = apt28 و Entity type = report	show reports about APT28
درست برای همان تفسیر	Scattered Spider و LAPSUS\$ (هر دو مشهور به فیشینگ صوتی)	uses [T1598.004] و Entity type = intrusion set	which intrusion sets use spearphishing
درست	No results	فیلتر با مقدار ناموجود	show reports about Atlantis group

۴.۳) اکشن Translate – ترجمه وفادار (بهبود ۳)

منوی Ask-AI تا پیش از این شش عمل داشت و کاربر چندزبانه نمی‌توانست متن را به زبان دلخواه بگیرد. اضافه شد: آیتم هشتم «Translate» با دیالوگ ورودی آزاد زبان مقصد، و mutation جدید aiTranslate (اسکیما + resolver + تابع دامنه) که ترجمه وفادار همان متن را برمی‌گرداند (حفظ معنا، ساختار و اصطلاحات فنی؛ بدون خلاصه‌سازی). تست زنده: ترجمه صحیح فارسی – «APT28» از ابزارهای فیشینگ استفاده می‌کند» – به همراه تست چند زبان دیگر؛ تأیید شد.

۴.۴) اکشن Improve writing (الف)

آیتم هفتم منو؛ همان قرارداد اصلاح املا اما با هدف صیقل نگارشی (روان‌سازی، لحن حرفه‌ای، بدون افزودن اطلاعات). resolver و تابع دامنه پیاده‌سازی و تست شد – تأیید شد.

۴.۵) تبدیل Indicator با aiConvertIndicator – AI (ب)

این mutation سال‌ها در اسکیما بود ولی resolver نداشت. پیاده‌سازی شد: دکمه «Convert with AI» در پنل جزئیات Indicator (صفحه Observations Indicators) با انتخاب فرمت STIX / SIGMA / YARA و دیالوگ نتیجه با Copy. نمونه خروجی واقعی تست (شاخص دامنه gold-026.goldgraph.example):

- دقیقاً برابر مقدار اصلی pattern با 2.1 نسخه indicator معتبر JSON شیء STIX:

- YARA: درست روی همان دامنه condition و strings قاعده معتبر با
 - SIGMA: dns_query / QueryName معتبر با نگاشت هوشمندانه YAML
- در هر سه فرمت وفاداری کامل بود و هیچ IOC جدیدی جعل نشده بود – تأیید شد.

۴.۶) گزارش موجودیت – aiThreatGenerateReport و aiVictimGenerateReport (۴/ج۴)

هر دو mutation (مانند ۴ب) فقط در اسکیمای بودند. پیاده‌سازی شد: تابع مشترک generateEntityReport که دانش موجودیت را از روابط واقعی گراف می‌سازد (grounding)، و دکمه «Generate AI report» (کامپوننت EntityAiReportButton با دیالوگ پاراگراف/لحن و نتیجه با Copy) روی صفحات Threat Actor (گروهی/فردی)، Country و Sector. در سطح API تست و تأیید شد؛ برای تست UI نهایی نیاز به داده دیتاست بود که به بخش ۶ می‌رسد.

۵. یافته‌های ریشه‌یابی

#	یافته	شرح	وضعیت
۱	خلاصه‌های AI Insights کش نمی‌شدند	تولید مجدد در هر باز کردن کشو	ترمیم شد (بهبود ۱)
۲	گیت EE و سقوط بی‌صدای NLQ	بدون هیچ خطایی به TopBar گشت‌وجوی معمولی برمی‌جست	ترمیم شد (بهبود ۲)
۳	چهار mutation مرده در اسکیمای	از PR شماره ۵۸۵۸ («معرفی GenAI بومی») فقط در ai.graphql اعلام بودند؛ resolver نداشتند و فراخوانی null برمی‌گرداند: aiThreatGenerateReport، aiVictimGenerateReport، aiConvertIndicator، ailImproveWriting	پیاپی‌سازی شد (۱۴ الف تا ۴ د)
۴	ناسازگاری دیتاست با صفحات UI	ولی صفر Intrusion Set ۱۸۶ و Country صفر Threat Actor، MITRE های؛ گروه Sector تنها یک Intrusion صورت‌در این دیتاست به شوند ذخیره می‌Set	در حال رفع با دیتاست‌های مرجع (بخش ۶)
۵	تفسیر باریک NLQ	تکنیک به تک «spearphishing» حل (فیشینگ صوتی) T1598.004 ترجای خانواده گسترده‌شد به (T1566/T1598)	ثبت در بهبودهای بعدی پرامپت NLQ
۶	حل بی‌صدای نام ناموجود	که در پلتفرم «Atlantis group» T1615 Group Policy به (نیست) جای پیام‌گره خورد – به Discovery «یافت نشد»	ثبت: نیاز به آستانه شباهت نام در resolve

نکته تاریخی مرتبط: در مسیر استریم LLM پیش‌تر باگ «nullnull» وجود داشت (دریافت content=null در چانک‌های gateway باعث الحاق رشته literal null می‌شد) که ریشه‌یابی و در هر دو مسیر Mistral و OpenAI در همین شاخه ترمیم شده بود؛ تمام تست‌های این چرخه نبود آن را تأیید کرد.

۶. وضعیت فعلی و گام‌های بعدی

- وارد کردن دیتاست مرجع رسمی OpenCTI (geography.json شامل کشورها/مناطق/شهرها و sectors.json) برای پرشدن صفحات جغرافیایی و سکتورها
- تبدیل و وارد کردن کهکشان MISP (threat-actor.json) به STIX 2.1 – بازیگران تهدید واقعی همراه روابط targets به کشورها – برای پرمحتوا شدن تست UI گزارش‌های ۴/ج۴
- گسترش اختیاری دکمه «Generate AI report» به صفحات Intrusion Set (خانه واقعی گروه‌ها در دیتاست ATT&CK)
- بهبودهای NLQ: آستانه شباهت نام در resolve مقادیر و ترجیح خانواده گسترده‌تر تکنیک‌ها

ضمیمه الف – وضعیت همه mutation های AI

اکتون	پیش از شاخه	کاربرد	mutation
فعال و تست شده	فعال (قفل EE در UI)	شش عمل متنی	aiFixSpelling / aiMakeShorter / aiMakeLonger / aiChangeTone / aiSummarize / aiExplain
فعال و تست شده (گیت رفع شد)	فعال در بک‌اند؛ قفل بی‌صدای UI	جست‌وجوی زبان طبیعی	aiNLQ
فعال و تست شده	فعال (قفل EE)	گزارش کانترینر	aiContainerGenerateReport
پیاده‌سازی + دکمه UI	بدون resolver (null)	گزارش بازیگر تهدید	aiThreatGenerateReport
پیاده‌سازی + دکمه UI	بدون resolver (null)	گزارش قربانی (کشور/سکتور/منطقه)	aiVictimGenerateReport
پیاده‌سازی + دکمه UI	بدون resolver (null)	تبدیل شاخص به STIX/SIGMA/YARA	aiConvertIndicator
پیاده‌سازی + آیتم منو	بدون resolver (null)	بهبود نگارش	aiImproveWriting
جدید: اسکیم + resolver + منو	وجود نداشت	ترجمه وفادار	aiTranslate
بدون تغییر	فعال (deprecated)	خلاصه فایل / تبدیل فایل به STIX	aiSummarizeFiles / aiConvertFilesToStix

ضمیمه ب – نقشه مسیر فایل‌های کلیدی

فایل	لایه
src/private/components/common/form/TextFieldAskAI.tsx	فرانت – منوی Ask-AI
src/private/components/common/ai/AllInsights.tsx، AISummary*.tsx، src/utis/ai/insightsCache.ts	فرانت – کشو Insights و کش
src/private/components/nav/TopBar.tsx + src/components/SearchInput.jsx	فرانت – NLQ
src/private/components/common/stix_core_objects/StixCoreObjectFileExport.tsx + StixCoreObjectAskAI.tsx	فرانت – گزارش کانترینر
src/private/components/common/ai/EntityAiReportButton.tsx (Threat Actor، Country، Sector صفحات Root در)	فرانت – دکمه‌های گزارش موجودیت
src/private/components/observations/indicators/IndicatorDetails.tsx	فرانت – تبدیل Indicator
src/private/components/agent/AgentPanel.tsx (مسیر /dashboard/agent)	فرانت – پنل ایجنت
src/modules/ai/ai.graphql + ai-resolver.ts + ai-domain.ts	بک‌اند – اسکیم و resolver
src/http/httpAgentProxy.ts	بک‌اند – پروکسی ایجنت